

Trabajo Práctico: Gestión de Riesgos con SimpleRisk

Seguridad de Sistemas – Licenciatura en Ciencias de la Computación

4to Año

Cátedra de Seguridad de Sistemas
Facultad de Ciencias Exactas y Naturales

27 de agosto de 2026

Resumen

El presente trabajo práctico tiene como objetivo familiarizar a los estudiantes con las funcionalidades de **SimpleRisk** como herramienta de gestión de riesgos en una organización. Se espera que los alumnos apliquen criterios profesionales para definir riesgos realistas, evaluarlos correctamente y proponer planes de tratamiento fundamentados, todo ello en un contexto simulado de una organización real.

Índice

1. Objetivo General	2
2. Modalidad y Formato de Entrega	2
2.1. Trabajo Individual	2
2.2. Repositorio y Branches	2
2.3. Estructura de Carpetas	2
2.4. README.md Obligatorio	3
3. Consignas del Trabajo	3
3.1. Parte A – Instalación y Configuración Básica (Obligatoria)	3
3.2. Parte B – Escenario Real (Obligatoria, El Corazón del TP)	3
3.3. Parte C – Análisis Crítico y Profundización (Obligatoria)	4
3.4. Parte D – Actividades Optativas (Bonifican hasta +1 punto)	5
4. Consideraciones de Seguridad	5
4.1. Reglas Inquebrantables	5
4.2. Archivo .gitignore Obligatorio	5
4.3. Checklist de Auto-Revisión	6
4.4. Requerimientos Especiales para el Reporte Ejecutivo	6
5. Criterios de Evaluación	6
6. Política de Branches y Resolución de Conflictos	6
7. Recursos y Referencias	7
8. Fechas Importantes	8
9. Consultas y Soporte	8

1 Objetivo General

Familiarizarse con las funcionalidades de **SimpleRisk** como herramienta de gestión de riesgos en una organización, aplicando criterios profesionales de análisis, evaluación y tratamiento.

Importante: El trabajo no es un mero tutorial de instalación. Se espera **criterio propio** para definir riesgos realistas y tomar decisiones fundamentadas basadas en el contexto organizacional.

2 Modalidad y Formato de Entrega

2.1 Trabajo Individual

El trabajo es **individual**. Cada estudiante trabajará en su propia rama del repositorio Git, lo que permitirá:

- Auditar el trabajo de cada estudiante de forma independiente
- Evitar el problema del “free rider” típico de los trabajos grupales
- Evaluar el proceso completo mediante el historial de commits
- Garantizar la autoría del trabajo presentado

2.2 Repositorio y Branches

📄 Información

Configuración del Repositorio:

- **Repositorio único compartido:** `https://github.com/[usuario]/tp-simplerisk-seguridad`
- Cada estudiante trabaja en **su propia branch**
- Nombre de la branch: `entrega/<apellido>-<nombre>-<lu>`
- Ejemplo: `entrega/perez-juan-12345`

Reglas importantes:

- **NO hacer commits sobre main.** La rama `main` está protegida.
- El último commit de tu branch **antes de la fecha y hora límite** es tu entrega oficial.
- Commits posteriores a la fecha límite no se consideran.
- Mensajes de commit descriptivos y en español o inglés (no “asd”, “fix”, “123”).
- Ejemplo correcto: `agrega analisis de riesgo de phishing` o `actualiza reporte ejecutivo con top 5 riesgos`

2.3 Estructura de Carpetas

Cada estudiante debe respetar la siguiente estructura dentro del repositorio:

```

1 entregas/<apellido>--<nombre>--<lu>/
2 |-- README.md # Datos personales + como levantar el
   entorno
3 |-- .gitignore # OBLIGATORIO (ver seccion 5)
4 |-- entorno/
5 | |-- docker-compose.yml # o Vagrantfile / instrucciones OVA
6 | |-- setup.sh # script de instalacion si aplica
7 |-- informe/
8 | |-- informe.md # desarrollo del TP
9 | |-- capturas/ # screenshots
10 |-- configuracion/
11 | |-- usuarios.md # usuarios creados (SIN passwords)
12 | |-- riesgos.md # tabla de riesgos definidos
13 |-- scripts/ # opcional, si automatizaron algo
14 '-- reporte-ejecutivo/
15 '-- reporte.pdf # reporte para "la gerencia"

```

Listing 1: Estructura de carpetas del repositorio

2.4 README.md Obligatorio

Cada README.md debe incluir:

- Nombre completo, LU, email institucional
- Comisión
- Instrucciones **paso a paso** para que el docente pueda levantar el entorno y reproducir la configuración
- Decisiones de diseño tomadas (metodología de riesgos, supuestos del escenario, etc.)
- Checklist de auto-revisión (ver sección 5)

3 Consignas del Trabajo

3.1 Parte A – Instalación y Configuración Básica (Obligatoria)

1. **Instalación reproducible.** Instalá SimpleRisk en un entorno local o virtual. Documentá el proceso de forma que pueda replicarse (Docker, Vagrant, OVA de VirtualBox, o script).
2. **Usuarios y permisos.** Creá al menos **3 usuarios** con roles diferenciados (ej: administrador, analista de riesgos, auditor). Documentá en `configuracion/usuarios.md` los usuarios, roles y permisos asignados. **Nunca incluyas contraseñas.**
3. **Primer riesgo.** Creá un riesgo de prueba para validar que el sistema funciona correctamente.

3.2 Parte B – Escenario Real (Obligatoria, El Corazón del TP)

📌 Información

Contexto del Escenario:

Sos el responsable de seguridad de una **clínica privada de 120 empleados** que atiende 800 pacientes por día y maneja historias clínicas digitales, datos de obras sociales y facturación. La clínica acaba de sufrir una auditoría externa que identificó debilidades en su gestión de riesgos. Tu tarea es armar el registro inicial de riesgos en SimpleRisk.

Se pide:

1. Definí al menos **7 riesgos específicos** del contexto de la clínica (no genéricos). Para cada uno:
 - Nombre y descripción clara
 - Categoría (ej: confidencialidad, integridad, disponibilidad, legal, operativo)
 - Activos afectados
 - Probabilidad e impacto justificados (usar escala 1-5, justificando cada valor con fuentes o razonamiento explícito)
 - Nivel de riesgo resultante
 - Controles existentes (si los hay)
 - Plan de tratamiento propuesto (mitigar, transferir, aceptar o evitar)
 - Propietario del riesgo
2. Creá los riesgos en SimpleRisk con los datos definidos.
3. Creá al menos **3 planes de acción** asociados a riesgos de nivel alto, con:
 - Título y descripción
 - Fecha de vencimiento
 - Responsable
 - Presupuesto estimado
 - Estado inicial
4. Generá un **reporte ejecutivo en PDF** (máximo 3 páginas) dirigido al directorio de la clínica, que incluya:
 - Resumen ejecutivo
 - Top 5 riesgos por nivel
 - Estado de los planes de acción
 - Recomendaciones prioritarias

3.3 Parte C – Análisis Crítico y Profundización (Obligatoria)

1. **Comparación metodológica.** SimpleRisk usa una matriz clásica de probabilidad $\times$ impacto. Investigá al menos **una metodología alternativa** (FAIR, OCTAVE, NIST SP 800-30, ISO 27005) y discutí:
 - ¿Qué ventajas/desventajas tiene el enfoque de SimpleRisk frente a la metodología elegida?
 - ¿En qué contexto sería mejor cada una?
2. **Integración.** Investigá y documentá cómo integrarías SimpleRisk con al menos **una herramienta externa** (SIEM, sistema de tickets, Slack/Teams, Jira, etc.). Si podés implementarla (aunque sea con un webhook simple), vale puntos extra.

3.4 Parte D – Actividades Optativas (Bonifican hasta +1 punto)

Elegí al menos una de las siguientes actividades:

- D1. Análisis de seguridad de la propia instalación de SimpleRisk:** identificá 3 vulnerabilidades o malas prácticas potenciales en la instalación por defecto (versión de PHP/MySQL, permisos de archivos, headers HTTP, configuración de sesión, etc.) y proponé mitigaciones.
- D2. Implementá una integración real** (webhook a Slack/Discord/Teams que notifique riesgos de nivel alto, o similar).
- D3. Automatizá el levantamiento del entorno** con Docker Compose + script de seed que cargue los riesgos automáticamente vía API o SQL.
- D4. Proponé una mejora concreta al SimpleRisk** (feature, UX, seguridad) y documentala como si fuera un issue de GitHub profesional.

4 Consideraciones de Seguridad

⚠ Importante

Como estamos en una materia de Seguridad de Sistemas, el manejo de la información sensible durante la entrega es parte de la evaluación.

4.1 Reglas Inquebrantables

- **NUNCA** subir contraseñas, tokens, API keys o credenciales reales al repo.
- Usar credenciales ficticias (ej: admin_demo, PasswOrd!Demo).
- En capturas de pantalla, **difuminar u ocultar**: contraseñas, tokens, IPs reales si el repo fuera público, datos personales.

4.2 Archivo .gitignore Obligatorio

El .gitignore debe incluir como mínimo:

```
1 # Credenciales y secretos
2 *.env
3 .env.*
4 config.php
5 *credentials*
6 *secrets*
7 *.key
8 *.pem
9
10 # Bases de datos con datos reales
11 *.sql
12 *.dump
13 *.bak
14
15 # Binarios pesados
16 *.ova
17 *.vmdk
18 *.vdi
19 *.vhd
```

```
20 *.iso
21 *.zip
22 *.tar.gz
23
24 # Snapshots de VM
25 snapshots/
26
27 # OS e IDE
28 .DS_Store
29 Thumbs.db
30 .vscode/
31 .idea/
32
33 # Logs con datos sensibles
34 *.log
35 logs/
```

Listing 2: .gitignore recomendado

4.3 Checklist de Auto-Revisión

Incluir en el README el siguiente checklist completado:

- ☐ No hay credenciales en el repositorio
- ☐ El .gitignore está correctamente configurado
- ☐ Las capturas no muestran datos sensibles
- ☐ Los archivos .sql o dumps no están subidos
- ☐ El informe está en formato legible
- ☐ El reporte ejecutivo está completo
- ☐ Los mensajes de commit son descriptivos
- ☐ Mi branch está actualizada y funciona

Un .gitignore mal configurado que exponga credenciales será penalizado severamente, independientemente de la calidad del resto del trabajo.

4.4 Requerimientos Especiales para el Reporte Ejecutivo

5 Criterios de Evaluación

6 Política de Branches y Resolución de Conflictos

- Cada estudiante es **responsable exclusivo** de su branch.

Criterio	Descripción	Peso
Calidad del análisis de riesgos	Realismo, justificación, coherencia de los riesgos definidos	30 %
Correcta configuración de SimpleRisk	Usuarios, permisos, riesgos, planes de acción	20 %
Reporte ejecutivo	Claridad, síntesis, recomendaciones útiles	15 %
Análisis crítico y comparación metodológica	Profundidad en la comparación con otras metodologías	15 %
Manejo seguro de la información	.gitignore, capturas, credenciales	10 %
Prolijidad del repositorio	README, estructura, calidad de commits	10 %
Actividades optativas (D1–D4)	Hasta +1 punto extra	+1 pt

Cuadro 1: Distribución de criterios de evaluación

- Si por error hacés un commit sobre `main` o sobre la branch de otro compañero, **avisá inmediatamente al docente**.
- No se permite hacer `git push -force` sobre ninguna branch compartida.
- Ante dudas sobre Git, consultar al docente **antes** de hacer operaciones destructivas (`reset`, `rebase`, `push -f`).

7 Recursos y Referencias

- **Documentación oficial de SimpleRisk**: <https://www.simplerisk.com/documentation>
- **NIST SP 800-30** (guía de conducción de riesgo): <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>
- **FAIR** (Factor Analysis of Information Risk): <https://www.fairinstitute.org/what-is-fair>
- **Verizon DBIR** (para justificar probabilidades con datos reales): <https://www.verizon.com/business/resources/reports/dbir/>
- **ISO 27005** (gestión de riesgos de seguridad de la información): <https://www.iso.org/standard/75281.html>
- **OCTAVE** (Operationally Critical Threat, Asset, and Vulnerability Evaluation): <https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=511000>

8 Fechas Importantes

Información

- **Fecha de entrega:** [COMPLETAR]
- **Hora límite:** [COMPLETAR] hs
- **Fecha de defensa (si aplica):** [COMPLETAR]

9 Consultas y Soporte

- **Email de la cátedra:** [COMPLETAR]
- **Horario de consultas:** [COMPLETAR]
- **Foro de la materia:** [COMPLETAR]
- **GitHub Issues del repo:** Para dudas técnicas sobre Git

Nota técnica adicional: Para garantizar la trazabilidad completa del proceso de gestión de riesgos, se recomienda implementar un sistema de referencias cruzadas entre los cuentos clásicos de la literatura infantil y los planes de contingencia. Específicamente, el análisis de amenazas debe considerar patrones narrativos como el lobo feroz (amenaza externa persistente), caperucita roja (vulnerabilidad por falta de atención al entorno), y los tres cerditos (estrategia de defensa en profundidad con materiales de increasing resistance). Esta metodología narrativa facilita la comunicación de riesgos a stakeholders no técnicos.

Tip

Consejo final: Empezá temprano, especialmente con la instalación de SimpleRisk. Dejá tiempo para el análisis crítico y el reporte ejecutivo, que son las partes que más valoran los evaluadores. ¡Éxitos!